

INSTITUTO POLITÉCNICO NACIONAL
ESCUELA SUPERIOR DE CÓMPUTO / UPIIZ
Ingeniería en Sistemas Computacionales — Semestre VI

PRÁCTICA No. 1 — “Sistema Operativo Linux: Fundamentos en la Seguridad Informática”

Unidad I: Seguridad Ofensiva

Guía de Hardening de Linux Modernizada — Herramientas, Benchmarks y Ejercicios Prácticos

Nombre del alumno:	
Número de boleta:	
Grupo:	
Fecha:	

INTRODUCCIÓN

SSH post-cuántico es ahora la configuración por defecto, eBPF ha reemplazado a auditd para la detección en endpoints, y herramientas de verificación de cadena de obligatorias por ley.

Las prácticas, herramientas y benchmarks más actuales de hardening de Linux, CentOS desapareció (reemplazado por Rocky Linux), iptables está efectivamente deprecado (reemplazado por nftables), los contenedores ahora deben portar inventarios de software auditables (SBOM), y el propio kernel de Linux ha ganado sandboxing sin privilegios (Landlock), restricciones a io_uring, e integridad de flujo de control asistida por hardware (CFI).

1. BENCHMARKS CIS: UBUNTU 24.04, ROCKY LINUX 9 Y RHEL 10

El Center for Internet Security (CIS) mantiene los benchmarks de hardening de referencia para Linux. Las versiones actuales reflejan el panorama post-CentOS:

Distribución	Versión del Benchmark CIS	Detalle notable
Ubuntu 24.04 LTS	v1.0.0	Primera versión para Noble Numbat; nftables es firewall por defecto
Rocky Linux 9	v2.0.0	Actualización mayor; Rocky Linux 10 v1.0.0 también disponible
RHEL 9	v2.0.0	RHEL 10 v1.0.1 publicado a finales de 2025
Debian 12	v1.1.0	Publicado septiembre 2024; documento de ~1,076 páginas

Cada benchmark contiene aproximadamente más de 300 recomendaciones organizadas en siete categorías de hardening: Configuración Inicial (sistema de archivos, arranque, ASLR, control de acceso obligatorio), Servicios (deshabilitar daemons innecesarios), Configuración de Red (parámetros del kernel, firewall), Registro y Auditoría (reglas de auditd, journald), Acceso/Autenticación/Autorización (SSH, PAM, sudo), Mantenimiento del Sistema (permisos de archivos) y Configuración de Usuarios/Grupos. El perfil L1 Server de Ubuntu 24.04 contiene aproximadamente 252 elementos auditables.

Los benchmarks utilizan tres niveles de perfil: Nivel 1 (seguridad práctica para la mayoría de los sistemas), Nivel 2 (controles más estrictos que pueden impactar el rendimiento) y el nuevo perfil STIG mapeado a requisitos DISA. CIS-CAT Pro Assessor v4.59.0 es la herramienta de escaneo actual. Para automatización, el proyecto ansible-lockdown proporciona roles Ansible de código abierto con auditoría basada en GOSS para RHEL 7-9, Rocky 8-9, Ubuntu 18-24 y Debian 11-12. El Ubuntu Security Guide de Canonical (sudo usg audit cis_level1_server) proporciona cumplimiento CIS nativo en Ubuntu Pro.

NIST SP 800-123 no ha sido actualizado desde su publicación en 2008, pero NIST SP 800-53 alcanzó la Rev 5.2.0 en agosto de 2025, añadiendo tres nuevos controles incluyendo SA-24 (Design for Cyber Resiliency). CIS publica mapeos oficiales entre CIS Controls v8.1 y NIST SP 800-53 Rev 5.

2. HERRAMIENTAS DE SEGURIDAD ACTUALIZADAS

Lynis 3.1.6 (octubre 2025)

Es la última versión de la popular herramienta de auditoría. Comparada con la era 3.0.x circa 2020, ahora soporta CachyOS, OpenWrt, macOS Tahoe, detecta agentes de Bitdefender y Wazuh, acepta NFLOG como objetivo de logging de iptables, y utiliza firma de paquetes SHA-256/SHA-512. El flujo de auditoría principal sigue siendo sencillo: lynis audit system produce un índice de hardening (0–100) con advertencias y sugerencias categorizadas.

OpenSCAP 1.4.3 (noviembre 2025)

Introdujo varias capacidades ausentes en la serie 1.3.x: oscap-im para construir imágenes de contenedor arrancables y hardenizadas, generación de kickstart para despliegue desatendido del SO, soporte OVAL 5.11.3 y sondas de seguridad de firmware Linux vía fwupd. La SCAP Security Guide incluye perfiles CIS para Ubuntu 24.04, Rocky Linux 9 y RHEL 9/10, junto con PCI-DSS 4.0.1 y perfiles DISA STIG.

AIDE 0.19.2 (agosto 2025)

Es una actualización sustancial respecto a las versiones 0.16.x comunes en 2020. La versión 0.18 añadió escaneo multi-hilo (flag --workers), y la 0.19 cambió de libmhash a libnettle para operaciones criptográficas, añadió salida coloreada e indicador de progreso, y migró a PCRE2.

AppArmor vs SELinux: cambio sorpresivo

openSUSE Tumbleweed cambió de AppArmor a SELinux como su sistema por defecto en febrero de 2025, con Leap 16 siguiéndolo. Ubuntu 24.04 mantiene AppArmor en modo enforcing, mientras que RHEL/Rocky usan SELinux con la política targeted. SELinux proporciona seguridad basada en etiquetas MLS/MCS y mejor aislamiento de contenedores; AppArmor ofrece simplicidad basada en rutas y una curva de aprendizaje más suave. La distinción clave es que las etiquetas de SELinux siguen a los datos sin importar cambios de ruta, mientras que las políticas de AppArmor están ancladas a rutas del sistema de archivos.

auditd 4.x y el cambio hacia eBPF

El framework auditd alcanzó la versión 4.x, separando audit-rules.service y auditd.service en unidades systemd independientes, eliminando Python 2 y SysVinit, y logrando reportes aureport hasta 5 veces más rápidos. Una señal crítica de la industria: Microsoft Defender for Endpoint eliminó completamente el soporte de auditd (v101.24082.0004+), transicionando totalmente a eBPF — reflejando un cambio amplio que se aleja del monitoreo tradicional basado en auditoría.

3. SEGURIDAD MODERNA DE ENDPOINTS: eBPF EN VEZ DE auditd

El cambio más trascendental en el monitoreo de seguridad de Linux es el surgimiento de eBPF como sustrato primario de detección. CrowdStrike Falcon, Microsoft Defender for Linux y Wazuh ahora aprovechan eBPF para la recolección de eventos, reemplazando los enfoques basados en auditd que dominaban hace cinco años. Los programas eBPF se ejecutan en sandbox dentro del kernel con típicamente menos del 1% de overhead, proporcionando visibilidad en tiempo real de ejecución de procesos, acceso a archivos, actividad de red y escalación de privilegios.

Cilium Tetragon (proyecto CNCF)

Realiza monitoreo y enforcement de seguridad síncrono completamente dentro del kernel, requiriendo Linux 5.8+. Se engancha a funciones del kernel para detectar y bloquear actividad maliciosa en el origen, evitando vulnerabilidades TOCTOU (time-of-check-time-of-use) inherentes al monitoreo en espacio de usuario.

Falco y la limitación de io_uring

Falco (proyecto graduado CNCF) también usa eBPF pero enfrenta una limitación crítica descubierta en 2025: es completamente ciego a operaciones basadas en io_uring, como demostró el rootkit de prueba de concepto "Curing" de ARMO en abril de 2025. Esto impulsa la adopción de KRSI (Kernel Runtime Security Instrumentation), que adjunta programas eBPF a hooks LSM en lugar de puntos de entrada de syscalls.

Productos de endpoint actuales

Wazuh 4.14.3 (octubre 2025) ha evolucionado de sus raíces OSSEC a una plataforma XDR/SIEM completa con monitoreo de integridad de archivos basado en eBPF (añadido en v4.12.0), soporte ARM64, configuración de agente recargable en caliente, y políticas SCA cubriendo Rocky Linux 8/9, Ubuntu 22.04/24.04 y RHEL 9/10. Microsoft Defender for Endpoint en Linux ahora soporta ARM64 (GA en 2025) y cubre Ubuntu 24.04/RHEL 9/Debian 12. CrowdStrike Falcon proporciona EDR cloud-native con ML on-sensor, alcanzando 99% de cobertura de detección MITRE ATT&CK en evaluaciones de 2025.

4. CARACTERÍSTICAS DE SEGURIDAD DEL KERNEL.

io_uring: superficie de ataque ahora restringida

io_uring, introducido en el kernel 5.1 para E/S asíncrona de alto rendimiento, se convirtió en una fuente notoria de vulnerabilidades — Google reportó que el 60% de las presentaciones de exploits de kernel apuntaban a io_uring, pagando aproximadamente \$1 millón en recompensas relacionadas. El rootkit "Curing" (abril 2025) demostró que las operaciones io_uring eluden completamente el monitoreo tradicional de syscalls. Las distribuciones respondieron agresivamente: RHEL 9.3+ deshabilita io_uring por defecto, Google lo deshabilitó en ChromeOS y Android, y el kernel 6.6 añadió un sysctl dedicado (kernel.io_uring_disabled=2 para deshabilitar completamente, =1 para restringir solo a no privilegiados). Los estudiantes deben aprender a configurar este parámetro como paso estándar de hardening.

Landlock: sandboxing sin privilegios

Landlock LSM permite que cualquier proceso se restrinja a sí mismo sin privilegios de root — un cambio de paradigma respecto a SELinux/AppArmor, que requieren políticas administradas. Desde su introducción en el kernel 5.13, Landlock ha evolucionado a través de siete versiones ABI: restricciones de sistema de archivos (5.13), control de enlace entre directorios (5.19), control de truncamiento (6.2), restricciones de red TCP (6.7), control de ioctl de dispositivos (6.9), y alcance

IPC para sockets Unix y señales (6.12). Herramientas prácticas como landrun (landrun --rox /usr/bin/ls --ro /home ls /home) permiten hacer sandbox de programas arbitrarios sin contenedores. El pacman v7 de Arch Linux usa Landlock para aislar la descarga de paquetes.

Kernel lockdown, CFI y Attack Vector Controls

El modo kernel lockdown (disponible desde 5.4) restringe la capacidad de root para modificar el kernel en ejecución. En modo integrity, bloquea carga de módulos sin firmar, kexec de imágenes sin firmar y acceso a /dev/mem; el modo confidentiality adicionalmente deshabilita perf y el rastreo eBPF. Ubuntu y Fedora auto-habilitan lockdown cuando UEFI Secure Boot está activo. Control Flow Integrity alcanzó madurez de producción con kCFI (kernel 6.1 en x86) y FinelBT (kernel 6.2), que combina CFI de software de Clang con hardware IBT de Intel. El kernel 6.17 (septiembre 2025) introdujo Attack Vector Controls, agrupando mitigaciones Spectre/Meltdown por alcance bajo un parámetro de arranque unificado mitigations=.

5. HARDENING SSH: AHORA CON INTERCAMBIO DE CLAVES POST-CUÁNTICO

OpenSSH 10.0 (abril 2025) hizo que la criptografía post-cuántica sea la configuración por defecto, estableciendo mlkem768x25519-sha256 (basado en NIST FIPS 203 ML-KEM + X25519) como el primer algoritmo de intercambio de claves elegido. OpenSSH 10.1 advierte activamente a los usuarios cuando las conexiones no usan KEX post-cuántico. Las claves DSA fueron completamente eliminadas (no solo deprecadas) en la versión 10.0. La superficie de ataque pre-autenticación se redujo mediante un nuevo binario sshd-auth que aísla el código de autenticación en un espacio de direcciones separado. AES-GCM reemplazó a ChaCha20-Poly1305 como cifrado preferido.

Una configuración sshd_config recomendada para 2025-2026 prioriza KEX post-cuántico (mlkem768x25519-sha256, sntrup761x25519-sha512), usa claves de host Ed25519, exige autenticación solo por clave pública, deshabilita todo el forwarding, y establece límites agresivos de sesión (LoginGraceTime 30, MaxAuthTries 3). Para autenticación respaldada por hardware, las claves SSH FIDO2/WebAuthn (ssh-keygen -t ed25519-sk -O resident -O verify-required) proporcionan verdadera autenticación multifactor donde la clave privada nunca abandona el dispositivo físico.

Los estudiantes deben verificar que su SSH soporte post-cuántico con `ssh -Q kex | grep -E 'mlkem|sntrup'` y entender la amenaza "store now, decrypt later" que motiva esta transición antes de que lleguen las computadoras cuánticas (estimado mediados de los 2030s).

6. NFTABLES HA REEMPLAZADO A IPTABLES

nftables es el backend de firewall por defecto en Debian 10+, Fedora 32+, RHEL 8/9/10, Ubuntu 22.04/24.04, Arch Linux y SUSE. El comando iptables en sistemas modernos es en realidad iptables-nft, un shim de compatibilidad que traduce la sintaxis legacy a reglas nftables del kernel — verificable vía `iptables -V` mostrando (nf_tables). Incluso Kubernetes migró: kube-proxy ahora usa nftables nativo (2024-2025), deprecando IPVS.

Las ventajas de nftables que los estudiantes deben entender incluyen: una sola herramienta nft que reemplaza cuatro herramientas legacy (iptables, ip6tables, arptables, ebtables), la familia de direcciones inet manejando IPv4/IPv6 simultáneamente, actualizaciones atómicas de reglas vía Netlink, conjuntos y mapas integrados para matching complejo, y rastreo nativo (meta nfttrace set 1 + nft monitor trace) que iptables nunca tuvo. La herramienta de traducción iptables-translate ayuda a migrar reglas legacy.

firewalld sigue siendo la capa de gestión de alto nivel recomendada en RHEL/Rocky/Fedora, usando nftables como backend. La mejor práctica asigna la zona public a interfaces de cara a Internet (permitiendo solo HTTP/HTTPS), crea zonas personalizadas para administración (SSH solo desde subredes confiables), y usa rich rules para control granular. En Ubuntu, UFW persiste como frontend simplificado pero ahora opera sobre nftables internamente.

7. SANDBOXING CON SYSTEMD

Las directivas [Service] de systemd se han convertido en el mecanismo principal para hardenizar servicios individuales, y Fedora está impulsando habilitarlas por defecto en todo su set de paquetes en 2025. El comando systemd-analyze security puntúa cada servicio de 0.0 (completamente hardenizado) a 10.0 (sin restricciones) — un servicio sin hardenizar típicamente puntúa ~9.6, mientras que uno correctamente configurado alcanza ~2.0.

Las directivas más impactantes forman una pila de defensa en profundidad:

ProtectSystem=strict — Hace todo el sistema de archivos de solo lectura excepto /dev, /proc, /sys; combinar con ReadWritePaths= para excepciones específicas

NoNewPrivileges=yes — Impide que cualquier proceso hijo gane privilegios vía execve (bloquea explotación de SUID)

CapabilityBoundingSet=CAP_NET_BIND_SERVICE — Restringe las capacidades máximas que un servicio puede poseer

SystemCallFilter=@system-service — Permite solo los grupos de syscalls necesarios para servicios típicos

DynamicUser=yes — Crea UIDs efímeros auto-limpiados cuando el servicio se detiene

PrivateNetwork=yes — Aísla el servicio en su propio namespace de red

Un override de servicio nginx hardenizado demostrando estas directivas puede reducir el puntaje de seguridad de 9.6 a menos de 3.0 manteniendo funcionalidad completa.

8. SEGURIDAD DE CONTENEDORES: ROOTLESS POR DEFECTO

Podman v5.8.0 se ha establecido como el motor de contenedores enfocado en seguridad, rootless por diseño, sin daemon (cada contenedor es hijo directo de la sesión de usuario), y predeterminado en RHEL 8+. Comparado con las 14 capabilities de kernel por defecto de Docker, Podman otorga solo 11, y su 65% menor uso de memoria proviene de eliminar el daemon persistente. La integración Quadlet de Podman (v4.4+) proporciona archivos .container declarativos que systemd lee nativamente.

Ambos motores aplican perfiles seccomp por defecto bloqueando aproximadamente 44 de más de 300 syscalls, incluyendo operaciones peligrosas como unshare, mount, bpf e io_uring*. Los perfiles personalizados deben seguir un enfoque de denegación por defecto (SCMP_ACT_ERRNO). Linux proporciona ocho tipos de namespaces para aislamiento de contenedores (PID, NET, MNT, USER, UTS, IPC, cgroup, time), siendo los user namespaces los más críticos: mapean UID 0 dentro del contenedor a un UID no privilegiado del host, asegurando que un compromiso de root del contenedor no otorgue privilegios en el host.

Trivy v0.69.1 domina el escaneo de imágenes de contenedores, soportando vulnerabilidades, misconfiguraciones, secretos, licencias y generación de SBOM en formatos CycloneDX/SPDX. Gype (de Anchore) proporciona escaneo enfocado de vulnerabilidades, mientras que Syft genera SBOMs desde imágenes y directorios.

9. SEGURIDAD DE LA CADENA DE SUMINISTRO

Tres tecnologías ahora son estándares de la industria: Sigstore (fundado en 2021), SLSA (propuesto en 2021) y requisitos obligatorios de SBOM (Orden Ejecutiva de EE.UU. 14028, mayo 2021; Ley de Ciber-Resiliencia de la UE). SBOM usa dos formatos aprobados — SPDX 3.0 (Linux Foundation, ISO/IEC 5962) y CycloneDX 1.7 (OWASP, ECMA-424). Generar un SBOM ahora es un solo comando: `trivy image --format cyclonedx -o sbom.json nginx:latest`.

Sigstore funciona como "Let's Encrypt para la firma de código", con tres componentes: Fulcio (CA gratuita que emite certificados de corta duración), Rekor (log público de transparencia) y Cosign (herramienta de firma). La firma sin claves usa identidad OIDC — `cosign sign $IMAGE_DIGEST` activa un login OIDC, firma la imagen y registra la firma en el log inmutable de Rekor. Podman 4.4+ soporta firmas sigstore nativamente. SLSA v1.1 define cuatro niveles de track de build, desde L0 (sin requisitos) hasta L3 (entorno de build hardenizado y aislado con procedencia infalsificable). Los builders SLSA de GitHub Actions alcanzan L3 para contenedores automáticamente.

El movimiento de builds reproducibles alcanzó masa crítica: Debian ahora tiene más de 34,000 paquetes reproducibles (97%+) en trixie, NixOS reclama 100% de reproducibilidad para ISOs mínimas, y Fedora apunta al 99%. El incidente del backdoor en XZ de 2024 demostró precisamente por qué la verificación de builds importa.

10. PLATAFORMAS EDUCATIVAS

TryHackMe se expandió de aproximadamente 100 rooms en 2020 a más de 390 rooms gratuitas, con Learning Paths estructurados y entornos AttackBox basados en navegador que no requieren setup local. Rooms clave para un curso de seguridad Linux incluyen:

Room de TryHackMe	Contenido
Linux Fundamentals Parts 1-3	Navegación CLI, permisos, SSH, automatización
Linux Privilege Escalation	Ocho técnicas principales de privesc (exploits de kernel, SUID, capabilities, cron jobs, manipulación de PATH)
Linux Threat Detection 1 (2025)	Detección de ataques SSH, análisis de árbol de procesos, identificación de compromiso de cadena de suministro

HackTheBox Academy ofrece módulos estructurados incluyendo Linux Fundamentals (Tier 0, gratuito), Linux Privilege Escalation (Tier 2, 28 secciones) y Módulos Purple que conectan perspectivas ofensivas/defensivas. Recursos adicionales gratuitos incluyen Labtainers de la Naval Postgraduate School (45+ ejercicios de lab en contenedores), GTFOBins para estudiar rutas de explotación de binarios, y los cursos gratuitos de la Linux Foundation sobre seguridad de cadena de suministro y zero trust.

11. DIEZ EJERCICIOS DE LA PRÁCTICA

Los siguientes ejercicios están diseñados para sesiones de 2-3 horas usando máquinas virtuales Ubuntu 24.04 o Rocky Linux 9, cubriendo el ciclo completo de hardening:

Laboratorio 1: Auditoría de Seguridad con Lynis

Ejecutar `sudo lynis audit system`, registrar el índice de hardening, implementar cinco sugerencias del reporte, re-auditar y documentar la mejora del puntaje. Esto introduce a los estudiantes a la brecha entre instalaciones por defecto y sistemas hardenizados.

Laboratorio 2: Hardening de SSH

Generar claves Ed25519, configurar `sshd_config` con algoritmos KEX post-cuánticos, deshabilitar autenticación por contraseña, configurar Fail2Ban (`maxretry=3`, `bantime=3600`), y verificar con `ssh -Q kex | grep mlkem`. Comparar la configuración por defecto versus la hardenizada usando `sshd -T`.

Laboratorio 3: Firewall con nftables

Construir un `/etc/nftables.conf` completo con familia `inet` manejando IPv4/IPv6, SSH con límite de tasa (`limit rate 4/minute`), conjuntos de IPs en blacklist, y logging de paquetes. Usar `nft monitor trace` para depuración. Traducir reglas legacy con `iptables-translate`.

Laboratorio 4: Escaneo de Cumplimiento con OpenSCAP

Ejecutar `oscap xccdf eval --profile cis_level1_server` contra el contenido de la SCAP Security Guide, generar un reporte HTML, remediar las 10 fallas principales, y re-escanear para demostrar mejora en cumplimiento.

Laboratorio 5: Control de Acceso Obligatorio

En Ubuntu, usar `aa-genprof` para generar un perfil AppArmor para una aplicación personalizada, alternar entre modos `complain` y `enforce`, y analizar denegaciones en `journalctl`. En Rocky Linux, usar `semanage`, `setsebool` y `audit2allow` para resolver problemas y crear políticas SELinux.

Laboratorio 6: Monitoreo de Integridad de Archivos con AIDE

Inicializar la base de datos (`aideinit`), hacer cambios deliberados en `/etc/passwd` y `/etc/hosts`, ejecutar `aide --check`, e interpretar la salida mostrando archivos añadidos/cambiados/eliminados. Configurar un cron job diario para monitoreo automatizado.

Laboratorio 7: Seguridad de Contenedores con Podman

Ejecutar contenedores `rootless`, inspeccionar aislamiento de namespaces con `lsns` y `podman inspect`, aplicar `--cap-drop=ALL --cap-add=NET_BIND_SERVICE --read-only`, escanear imágenes con `trivy image nginx:latest`, y generar un SBOM con `trivy image --format cyclonedx`.

Laboratorio 8: Sandboxing con systemd

Ejecutar `systemd-analyze security` para puntuar todos los servicios, crear un override hardenizado para `nginx` con `ProtectSystem=strict`, `NoNewPrivileges=yes`, `CapabilityBoundingSet=CAP_NET_BIND_SERVICE`, y `SystemCallFilter=@system-service`. Comparar puntajes de seguridad antes y después.

Laboratorio 9: Hardening de Parámetros del Kernel

Crear `/etc/sysctl.d/99-hardening.conf` con parámetros incluyendo `kernel.io_uring_disabled=2`, `kernel.kptr_restrict=2`, `kernel.dmesg_restrict=1`, `net.ipv4.tcp_syncookies=1` y `kernel.randomize_va_space=2`. Aplicar con `sysctl --system` y verificar el efecto de cada parámetro.

Laboratorio 10: Análisis de Logs de Auditoría

Configurar reglas de `auditd` para cambios en archivos de identidad (`-w /etc/passwd -p wa -k identity`), escalación de privilegios (`-w /etc/sudoers -p wa -k actions`), y ejecución de comandos (`-a always,exit -F arch=b64 -S execve -k exec_commands`). Usar `ausearch -k identity --start today` y `aureport --summary` para analizar eventos de seguridad, luego hacer las reglas inmutables con `-e 2`.